



QUIIAM:

**Servizio gestito per l'Identity Access
Management per le Applicazioni per
INRIM**

Sommario

Contents

1	Introduzione	3
2	Servizi gestiti	3
3	La proposta.....	4
3.1	Possibili configurazioni del servizio	4
3.1.1	Soluzione in alta affidabilità o non ridondante	4
3.1.2	Versione del software	6
3.1.3	Dimensionamento delle macchine	7
3.2	Descrizione del servizio.....	7
3.3	Runtime del servizio (a canone).....	8
3.4	Assistenza H24	8
3.4.1	Flusso operativo	9
3.4.2	Piano di delivery	9
3.5	Vantaggi.....	10
4	Offerta economica	11
4.1.1	Configurazione Ridondata in HA	11
4.1.2	Servizi di configurazione di dettaglio.....	11
4.1.3	Opzione estensione supporto H24	12
4.1.4	Licenze RedHat Enterprise per Keycloak (opzionale)	12

1 Introduzione

La trasformazione digitale introduce nuove metriche e nuove tecnologie, promuove un approccio al lavoro basato sulla digitalizzazione dei processi, sull'utilizzo di un numero sempre più elevato di applicazioni, sulla condivisione di dati e informazioni in tempo reale.

L'aumento della complessità applicativa e infrastrutturale pone in primo piano i bisogni di efficienza, controllo e sicurezza.

2 Servizi gestiti

I sistemi IT sono sempre più complessi perché attraverso i canali e gli strumenti digitali passa una parte sempre più consistente del business delle imprese.

Sempre di più il sistema IT si configura come una leva di business e non più un semplice "strumento di supporto" (di cui minimizzare i costi). Le aziende oggi chiedono ai propri tecnici informatici di **essere sempre di più** una spinta per l'innovazione e la trasformazione digitale e di **essere sempre di meno** semplici "guardiani" del buon funzionamento di macchine e software.

Non è sempre facile, però, gestire i propri sistemi informatici autonomamente. Dedicare tempo e risorse all'IT è complesso, costoso e soprattutto rischioso. La complessità dei sistemi fa sì che le risorse a essi dedicate debbano essere altamente specializzate. E' difficoltoso dotarsi di personale qualificato e, soprattutto, di riconoscerne le competenze necessarie in fase di assunzione. Ma, ancora più importante, queste competenze sono "solamente" di contenimento e non risultano utili per un utilizzo strategico e propulsivo dell'informatica.

Il modello dei servizi gestiti (MS-Managed Service) viene ormai ampiamente riconosciuto come un approccio molto efficace, in grado di risolvere problematiche tipiche di una gestione tradizionale dei sistemi e della sicurezza IT in azienda, migliorandone al contempo l'efficacia, la sicurezza, la capacità di adeguamento tecnologico, la soddisfazione degli utenti interni.

Intesys e la sua controllata Intesys Networking lavorano nel campo della gestione di reti e sistemi da più di 20 anni e, forti di questa esperienza, hanno elaborato una serie di servizi gestiti che possano aiutare in modo effettivo le aziende a rimanere al passo con le innovazioni tecnologiche mitigando i loro rischi di attacchi, intrusioni e blocchi di sistemi.

Intesys e Intesys Networking sono entrambe certificate ISO27001 ed hanno entrambe intrapreso il percorso di certificazione ISO20000 (qualità dei servizi IT) Sono quindi in grado di garantire ai propri clienti degli elevati standard procedurali di gestione dei servizi IT con particolare riferimento alla sicurezza dell'informazione.

3 La proposta

Inrim vuole utilizzare uno strumento per gestire in modo sicuro e resiliente i processi di Identity ed Access Management per i propri applicativi.

La proposta di Intesys è di utilizzare le più affidabili e supportate tecnologie CloudNative garantendo un servizio scalabile, sicuro ed efficiente a Inrim.

In particolare, QUIIAM vuole essere una piattaforma di accesso e autenticazione in grado di gestire l'integrazione con i diversi applicativi aziendali e ai rispettivi protocolli di autenticazione garantendo performance di sicurezza e contemporaneità degli accessi.

L'obiettivo è progettare un servizio per Inrim che:

- garantisca un approccio SSO;
- sia sicuro e costantemente aggiornato;
- sia monitorato 7/5 e 24/7;
- sia personalizzato sulle esigenze del Cliente;
- possa scalare su licenza Enterprise se necessario;
- possa essere gestito su infrastruttura "on Prem del Cliente o in Private Cloud;
- possa essere in alta affidabilità (HA);

La piattaforma sarà implementata sul datacenter del Inrim (PSN) On Premise, in tecnologia Keycloak

3.1 Possibili configurazioni del servizio

3.1.1 Soluzione in alta affidabilità o non ridondante

E' possibile avere due tipi di installazione per la soluzione Keycloak, in ambiente ridondato e non. Di seguito il dettaglio degli ambienti.

3.1.1.1 Scenario non ridondante

Verranno realizzati due ambienti operativi:

- Ambiente di **test**
 - Una macchina virtuale per Keycloak
 - Una macchina virtuale per DB Postgres
- Ambiente di **produzione**
 - Una macchina virtuale per Keycloak
 - Una macchina virtuale per DB Postgres

3.1.1.2 Scenario in alta affidabilità

Verranno realizzati due ambienti operativi:

- Ambiente di **test**

- Una macchina virtuale per Keycloak
 - Una macchina virtuale per DB Postgres
- Ambiente di **produzione**
 - Due macchine virtuali per Keycloak in configurazione HA
 - Tre macchine virtuali per DB Postgres in configurazione cluster

Esistono molte ragioni per preferire una architettura ridondata.

Eccone alcune:

Continuità del servizio di autenticazione come requisito di sicurezza

L'autenticazione non è un servizio come gli altri: se cade il CRM, gli utenti non lavorano. Se cade l'Identity Provider, **nessuno può accedere a nulla**. Un singolo nodo Keycloak + DB è un Single Point of Failure (SPOF) che rende ogni altro investimento in sicurezza inutile durante un'interruzione.

Resilienza agli attacchi DoS/DDoS

Un'architettura flat è trivialmente abbattibile con un attacco volumetrico o anche solo con un burst di autenticazioni concorrenti. Con un cluster Keycloak bilanciato:

- il carico si distribuisce su più nodi
- un nodo sotto attacco può essere isolato senza interrompere il servizio
- il rate limiting può essere applicato upstream senza impattare la disponibilità

Protezione dal ransomware e dalla corruzione del DB

Con un singolo PostgreSQL/MySQL, un ransomware o una corruzione del datafile di autenticazione significa **lock-out totale** di tutti gli utenti. La ridondanza impone:

- replica sincrona/asincrona (es. PostgreSQL streaming replication o Patroni)
- failover automatico senza perdita di sessioni attive
- point-in-time recovery senza dover resettare le credenziali

Conformità NIS2

- **NIS2 (D.Lgs. 138/2024), Art. 21** — obbligo di misure di continuità operativa per i sistemi critici, tra cui esplicitamente i sistemi di gestione degli accessi
- **ISO 27001:2022, controllo 8.6** — disponibilità delle risorse di elaborazione deve essere pianificata e monitorata

Un'architettura single-node espone il cliente a **non conformità formale**

Zero-Downtime durante aggiornamenti e patching

Le CVE su Keycloak sono frequenti (basti vedere il ritmo di release). Con un singolo nodo, ogni aggiornamento di sicurezza richiede una finestra di manutenzione con downtime. Un cluster permette **rolling upgrade**: si aggiorna un nodo alla volta, il servizio non si interrompe mai. Per un

cliente con obbligo di patching rapido (es. entro 72h su vulnerabilità critiche secondo NIS2), questa è una differenza sostanziale.

Segregazione e blast radius

Con architettura ridondante è possibile segmentare:

- **Keycloak realm separati per ambiente** (prod/staging) su nodi dedicati
- **Admin console isolata** su un nodo non esposto a internet
- **Failure isolation:** un nodo compromesso non abbatta l'intera catena di autenticazione

Con architettura flat, la superficie di attacco e il blast radius coincidono con l'intero sistema IAM.

Session persistence e token continuity

In caso di failover su architettura flat, **tutte le sessioni attive vengono invalidate**: gli utenti devono ri-autenticarsi, spesso in un momento già critico (es. durante un incidente). Con Infinispan cluster (il cache distribuito interno di Keycloak) e DB replicato, le sessioni sopravvivono al failover del singolo nodo — zero disruption per gli utenti autenticati.

3.1.2 Versione del software

Il software può essere fornito in modalità supportata o no.

Intesys Networking è partner di Red Hat.

Nella versione supportata il software applicativo richiede anche un sistema operativo supportato RHEL.

Le differenze di sicurezza rilevanti sono queste:

Patch e CVE

La RedHat Build riceve backport di security fix su versioni certificate e stabili, con SLA definiti e notifiche proattive via RedHat Security Advisories (RHSA). La community applica i fix solo sulla versione più recente — se sei indietro di qualche release, sei esposto.

Il nostro servizio di supporto prevede la gestione delle patch a condizione che:

- Esista la Subscription RHEL e RHBK attivate sui SKU che ci servono
- Ci sia accesso al Red Hat Customer Portal o Pool ID/Activation Key per registrare le VM negli account del cliente
- Conferma che le subscription includono il canale di backport CVE (senza questo, la versione "supportata" non si distingue dalla community)

Supporto e accountability

Con RedHat è presente un contratto di supporto, quindi qualcuno risponde formalmente in caso di vulnerabilità critica. Con la community si può aprire una issue su GitHub ma nessuno garantisce tempi di risposta, il che è problematico in contesti NIS2 dove bisogna dimostrare un processo di gestione delle vulnerabilità.

FIPS 140-2

RedHat supporta esplicitamente la modalità FIPS per la crittografia. La community non garantisce questa configurazione out-of-the-box.

Hardening e configurazione di default

La distribuzione Red Hat tende ad avere default più conservativi e documentazione di hardening ufficiale. La community lascia più libertà ma anche più superficie di attacco se non configurata correttamente.

Il codice core è lo stesso — Keycloak è open source e Red Hat ne è il principale maintainer. Quindi non ci sono differenze architetturali nel motore di autenticazione, nei protocolli supportati (OIDC, SAML) o nelle funzionalità.

In offerta economica verrà evidenziato a parte il costo della versione supportata

3.1.3 Dimensionamento delle macchine

In base alla stima del cliente di circa 500 utenti con un refresh dei token ogni 300 secondi (5 minuti è la durata tipica di un access token) le macchine previste per l'infrastruttura di produzione saranno 2, con ognuna 2 vCPU. Questo perchè Keycloak indica:

- 1 vCPU gestisce 15-20 login al secondo
- 1 vCPU gestisce circa 200 refresh token al secondo
- Allocare il 150% di capacità extra per gestire picchi imprevisti

I nostri dati sono:

- 500 utenti / 300 secondi = 2 refresh/secondo
- Tutti i 500 utenti si loggano all'interno di una finestra di 30 minuti: 500 login / 1800 secondi = 0,3 login/secondo

Gestiremmo il tutto con 1 vCPU. Tenendoci il 150% di extra, arriviamo a 3 vCPU. Con una configurazione HA abbiamo 2 VM con 2 vCPU. Come RAM il minimo indicato per JVM in produzione è 4 GB RAM.

3.2 Descrizione del servizio

Si prevede la fornitura del servizio QUIIAM by Keycloak secondo le qui di seguito riportate fasi di lavoro e attività:

- Analisi e Assessment
- Configurazione e avvio:
 - Allineamento e accesso la sistema del Cliente (On Prem o Cloud Privato)

- Configurazione e gestione via IAC delle risorse necessarie (VM)
- Installazione e configurazione Keycloak
- Configurazione con il Cliente del Firewall e Web Application Firewall
- Supporto per l'integrazione Protocolli Applicativi del Cliente
- Finalizzazione configurazione Keycloak
- Supporto per la migrazione utenti
- Test e Collaudo

Il servizio non prevede la configurazione dei Realm e le integrazioni coi vari sw.

3.3 Runtime del servizio (a canone)

Il canone di servizio comprende le seguenti attività:

- Almeno 1 update di major release all'anno su Test e Produzione
- Monitoraggio 8/5 (opzionalmente 24/7)
- Security Patching
- Supporto e Priority SLA su istanza Keycloak (4 ore presa in carico, 8 ore risoluzione best effort)
- Backup & restore
- Allineamento cliente su presenza nuovi aggiornamenti di sicurezza
- Allineamento cliente su funzionalità delle nuove versioni
- Controllo proattivo sulle metriche infrastrutturali
- Controllo proattivo sulle metriche applicative
- Gestione VPN
- Backup infrastruttura Keycloak (se in Private Cloud su nostra infrastruttura)

Per il monitoraggio proattivo sia delle metriche infrastrutturali che applicative chiediamo che sia instaurata una VPN site-2-site con la nostra infrastruttura, per poter utilizzare gli strumenti di monitoraggio di Intesys Networking (LibreNMS e Grafana/Prometheus). In caso questa connettività non possa essere instaurata, dovremo appoggiarci su sistemi di monitoraggio e alerting forniti dal cliente, configurati secondo nostre indicazioni.

Per l'accesso e la configurazione delle VM, nonché per la loro manutenzione, chiediamo che siano instaurate VPN personali che forniscano accesso all'infrastruttura cliente. Tramite queste VPN dovremo poter accedere alle VM che formeranno il servizio QUIIAM.

3.4 Assistenza H24

L'obiettivo di questo servizio è di offrire un'assistenza rapida negli orari non lavorativi per malfunzionamenti ritenuti particolarmente critici. Il servizio di reperibilità e supporto H24 viene reso disponibile 24h/24h, 7g/7g, 365gg/anno:

- fuori orario di ufficio (quindi fuori dalla fascia 9:00 – 13:00 / 14:00 – 18:00);
- in orario d'ufficio festivi e prefestivi.

Il servizio garantisce:

- Reperibilità telefonica H24 su un numero dedicato di un interlocutore preparato ad accogliere le segnalazioni del cliente;
- Attività affidate a personale con skill professionali adeguati a identificare i problemi nelle aree tecniche definite dal documento tecnico di progetto.

Il canone annuo copre il servizio di reperibilità su un team di tecnici skillati per essere in grado di effettuare gli interventi urgenti. Per ogni chiamata urgente viene caricato un costo di 100€+IVA che copre la prima mezz'ora di intervento.

Nel caso sia necessario prevedere operatività compiuta da terze parti, Intesys rifatturerà i relativi costi al cliente alla quotazione cui li ottiene. Gli interventi di terze parti che si rendano necessari per concludere l'intervento dovranno sempre essere preventivamente concordati con il cliente.

3.4.1 Flusso operativo

Il flusso operativo del servizio H24 prevede:

Apertura Incident con l'intervento immediato di un operatore specializzato che raccoglie la segnalazione di fault e la segue fino al termine del disservizio. La presa in carico avviene con una segnalazione via alert dai nostri sistemi di monitoring all'operatore:

- nella fascia 18:00-9:00 e in tutti i giorni non lavorativi.
- via mail a supporto@inetworking.it.

Operatività

1. Presa in carico del problema prima indagine con il referente del Cliente
2. Attività di indagine volta ad identificare la/le cause del disservizio.
3. Azioni di ripristino e soluzione – per quanto possibile – dei problemi imputabili al disservizio.
4. Coinvolgimento del cliente nel processo decisionale in caso sia necessario compiere interventi particolarmente penalizzanti per il servizio complessivo (alti costi, tempi di fermo lunghi, sostituzione parziale o totale di apparecchi, necessità di upgrade non previste/prevedibili) o sia necessario concordare le azioni da intraprendere.
5. Sessione di testing e verifica successiva alla risoluzione del guasto

Chiusura del guasto sui malfunzionamenti identificati e report delle misure adottate. Eventuale raccomandazione al cliente di azioni migliorative.

3.4.2 Piano di delivery

Di seguito si descrivono i principali step operativi del piano di delivery

Setup

- Identificazione interlocutori, definizione flussi comunicazione
- Attivazioni VPN personali per installazione e operatività
- Richiesta e verifica realizzazione VM
- Installazione Keycloak e PostgreSQL (istanze singole, sia TEST che PROD)
- Passaggio configurazioni bilanciamento traffico HTTPS
- Configurazione connessione LDAP

- Test funzionamento e HA
- VPN con Intesys Networking e configurazione monitoraggio e alerting

Se la VPN site-2-site per il monitoraggio lato Intesys Networking non è fattibile, ci sono da aggiungere 2 gg di lavoro nelle fasi SETUP per il nuovo monitoraggio/alerting.

3.5 Vantaggi

La soluzione descritta presenta due importanti elementi di vantaggio:

- È erogata in forma di servizio (in cloud o on premise) quindi senza nessun impatto sullo staff tecnico del cliente che non ha necessità né di acquisire skill complessi ma non strategici, né di presidiarne il funzionamento. In caso di erogazione del servizio in cloud il cliente non avrà nessun impatto nemmeno sulla propria architettura. Nel caso on-premise dovrà semplicemente mettere a disposizione le risorse concordate che verranno gestite successivamente da Intesys Networking.
- È totalmente costituita da tools software di tipo opensource che garantiscono apertura agli standard, basso vendor lock-in, investimenti di progetto contenuti

4 Offerta economica

4.1.1 Configurazione Ridondata in HA

Descrizione	Quantità	Prezzo unitario	Prezzo totale
Una tantum installazione e configurazione Keycloak in ambiente ridondato (2 macchine test e cinque macchine produzione)	1	6400 €	6400 €
Canone annuale supporto e manutenzione infrastruttura	1	4200 €	4200 €

4.1.2 Servizi di configurazione di dettaglio

I servizi di configurazione sono quotati a giornate che costerebbero 580 € ciascuna ma abbiamo applicato uno sconto flat su tutte.

Descrizione	Giorni stimati per l'attività	Prezzo totale di listino	Prezzo scontato 10%
- Configurazione base - Configurazione REALM - federazione LDAP - client standard	10	5800 €	5220 €
Configurazione SPID e CIE	9	5220 €	4698 €
2FA OTP via e-mail	3	1740 €	1566 €
2FA Google Authenticator	1	580 €	522 €
2FA Passkey	3	1740 €	1566 €
Form OTP e customizzazioni Buffer analisi e gestione form OTP	5	2900 €	2610 €
Customizzazioni:	4	2320 €	2088 €

- recupero password - invio password - email custom			
Plafond di 50 ore servizi professionali a consumo	80 €/ora	4000 €	3600 €

4.1.3 Opzione estensione supporto H24

Descrizione	Costo
Canone annuo estensione del supporto da 8x5 ad H24	4500 €

4.1.4 Licenze RedHat Enterprise per Keycloak (opzionale)

Descrizione	Quantità	Prezzo unitario	Prezzo totale
Canone annuale licenze RedHat Enterprise Linux (RHEL) con supporto premium per ambiente prod (cod. RH00003)	2	1257 €	2514 €
Canone annuale licenze RedHat Enterprise Linux (RHEL) con supporto standard per ambiente test (cod. RH00004)	1	773 €	773 €
Canone annuale licenze Red Hat Keycloak con supporto premium - Red Hat Runtimes, Premium (2 Cores or 4 vCPUs) per ambiente prod (cod. MW00277)	1	1452 €	1452 €
Canone annuale licenze Red Hat Keycloak con supporto standard 8x5 per ambiente test (cod. MW00280)	1	968 €	968 €

Le licenze RedHat sono fornite solo per l'ambiente Keycloak, (postgres è escluso dall'offerta)

Come da richiesta del cliente l'offerta è valida per un servizio triennale con fatturazione annuale anticipata. I prezzi si intendono IVA esclusa.

Fatturazioni e termini di pagamento

Il corrispettivo relativo al canone annuo verrà fatturato anticipatamente all'inizio del periodo di servizio

Il corrispettivo relativamente ai servizi una tantum dopo consegna lavori e avvio in produzione del servizio (comunque non oltre 30gg di calendario dopo la consegna lavori)

Il corrispettivo relativo ai servizi professionali (opzionale, eventuale) dopo consegna lavori e accettazione consuntivo ore

Tutte le fatture dovranno essere saldate entro il termine di 30 giorni dffm mediante bonifico bancario sul conto corrente intestato alla società n. 675048 presso la Banca Popolare dell'Emilia Romagna, Agenzia Verona Sede codici ABI 5387 e CAB 11700 (IBAN n. IT 79 Y 05387 11700 000000675048)

Verona, 12/06/2026

In fede

Alessandro Caso

Amministratore Delegato

Intesys Networking S.r.l.



Per accettazione – Il Cliente

(timbro e firma del Legale Rappresentante)